

Rapport de TP : contournement de l'SSL pinning avec Frida

Ezbiri Amira

Avertissement éthique. Ce TP doit être réalisé uniquement dans un cadre légal et autorisé : tests sur vos propres applications et appareils, environnement de formation, audit approuvé. L'objectif est l'inspection du trafic HTTPS à des fins de sécurité. Les techniques présentées ci-dessous ne doivent pas être utilisées en production ni sur des systèmes tiers.

Table des matières

1	Objectifs du TP	3
2	Pre-requis et environnement	3
3	Principe général	3
4	Etape 1 - Installation de Frida	4
4.1	Cote PC	4
4.2	Cote Android	4
4.3	Validation Frida	4
5	Etape 2 - Configuration du proxy TLS	4
5.1	Lancement du proxy	4
5.2	Installation du certificat CA	4
5.3	Redirection du trafic	5
6	Etape 3 - Lancement de l'application sous Frida	5
7	Etape 4 - Bypass SSL pinning en Java	5
7.1	Résultat attendu	5
8	Etape 5 - Cas avancé : pinning natif	6
9	Analyse des captures d'écran	6

10 Resultats obtenus	8
11 Difficultes et depannage	9
11.1 Erreur de connexion a frida-server	9
11.2 Aucun trafic dans le proxy	9
11.3 Crash au demarrage	9
12 Conclusion	9

1 Objectifs du TP

Ce TP a pour but de mettre en place une chaine d'interception du trafic HTTPS sur Android, puis de neutraliser les mecanismes de protection qui empechent l'inspection du contenu chiffre.

Les objectifs pratiques sont les suivants :

- installer et verifier Frida cote PC, puis demarrer `frida-server` sur Android ;
- configurer un proxy TLS sur le poste d'analyse ;
- installer le certificat CA du proxy sur l'appareil ;
- contourner l'SSL pinning par hooks Java (`TrustManager`, `Conscrypt`, `OkHttp`, `WebView`) ;
- diagnostiquer le cas ou le pinning est implemente en natif ;
- valider le succes du contournement en observant le trafic HTTPS dechiffre dans le proxy.

2 Pre-requis et environnement

Le TP s'appuie sur les elements suivants :

- un PC Windows, macOS ou Linux avec droits administrateur ;
- Python 3.8+ et `pip` ;
- Android Platform Tools (`adb`) ;
- Frida cote PC et `frida-server` sur l'appareil, avec la meme version ;
- un appareil Android 8+ avec le debogage USB active ;
- un proxy TLS de type Burp Suite ou mitmproxy ;
- une application cible Android a auditer dans un cadre autorise.

3 Principe general

Le flux de travail adopte dans ce TP repose sur quatre briques :

1. le **proxy TLS** intercepte le trafic HTTPS ;
2. le **certificat CA** du proxy permet a l'appareil de faire confiance a l'intercepteur ;
3. **Frida** injecte du code dans le processus de l'application cible ;
4. les **hooks** neutralisent les verifications de certificat et les couches d'SSL pinning.

Sans contournement, l'application refuse souvent la connexion car elle compare le certificat presente par le proxy avec une empreinte attendue. Une fois les hooks actifs, la connexion

se fait normalement et le proxy peut afficher les requetes, les en-tetes et le corps des echanges en clair.

4 Etape 1 - Installation de Frida

4.1 Cote PC

L'installation standard consiste a mettre a jour les outils Python :

```
python -m pip install --upgrade frida frida-tools
frida --version
python -c "import frida; print(frida.__version__)"
```

Cette etape verifie que le client Frida est correctement installe et que la version est connue, ce qui est indispensable pour faire correspondre le serveur Android.

4.2 Cote Android

L'appareil doit etre accessible via ADB :

```
adb devices
adb shell getprop ro.product.cpu.abi
```

La seconde commande permet d'identifier l'architecture CPU afin de telecharger l'archive `frida-server` correspondante. Apres transfert sur l'appareil, le serveur est lance dans `/data/local/tmp/`.

4.3 Validation Frida

Une fois le serveur demarre, `frida-ps -Uai` doit lister les applications et les processus accessibles. Cette verification confirme que la liaison PC <-> appareil fonctionne et que Frida peut injecter du code dans un processus Android.

5 Etape 2 - Configuration du proxy TLS

5.1 Lancement du proxy

Burp Suite ou mitmproxy est execute sur le PC, en general sur le port 8080. Le proxy doit etre joignable depuis l'appareil Android.

5.2 Installation du certificat CA

Le certificat racine du proxy est exporte puis installe sur l'appareil. Cette operation permet au systeme Android de faire confiance au proxy pendant l'interception TLS.

5.3 Redirection du trafic

Selon le contexte, le trafic peut etre redirige via :

- un proxy Wi-Fi configure sur le telephone ;
- une redirection ADB pour un emulateur ou un test USB ;
- une configuration specifique a l'application lorsque c'est possible.

6 Etape 3 - Lancement de l'application sous Frida

Deux modes sont utilises :

- **spawn** : Frida lance l'application et injecte le script tres tot ;
- **attach** : Frida s'accroche a une application deja lancee.

Le mode `-f` est privilegie quand l'application initialise le pinning tres tot, car il permet d'appliquer les hooks avant les verifications TLS sensibles.

7 Etape 4 - Bypass SSL pinning en Java

Le script universel place des hooks sur plusieurs points strategiques :

- `SSLContext.init` pour injecter un `TrustManager` permissif ;
- les methodes `checkServerTrusted` et `checkClientTrusted` des implementations de `X509TrustManager` ;
- les classes `Conscrypt (TrustManagerImpl)` sur Android modernes ;
- `okhttp3.CertificatePinner.check` ;
- `android.webkit.WebViewClient.onReceivedSslError`.

L'objectif est de couvrir les bibliotheques et les API les plus frequentes sans dependre d'une seule implementation. Si l'application utilise un package `okhttp` ombrage, les noms de classes doivent etre adaptes au namespace reel.

7.1 Resultat attendu

Lorsqu'une connexion TLS est etablie, le script doit afficher des messages de type `[+] SSL bypass: ...` dans la console Frida. En parallele, le proxy commence a voir les requetes HTTPS de l'application.

8 Etape 5 - Cas avance : pinning natif

Certaines applications déplacent la verification dans une bibliotheque native basee sur BoringSSL ou OpenSSL. Dans ce cas :

- les hooks Java peuvent ne pas suffire ;
- il faut tracer les symboles TLS natifs ;
- le retour d'une fonction de verification peut etre force a OK ;
- le comportement varie selon la version d'Android et la pile reseau utilisee.

Cette etape est un diagnostic complementaire lorsque le proxy ne recoit toujours aucun trafic lisible malgre les hooks Java.

9 Analyse des captures d'ecran

Les captures fournies illustrent le deroulement du TP et les points de controle principaux.

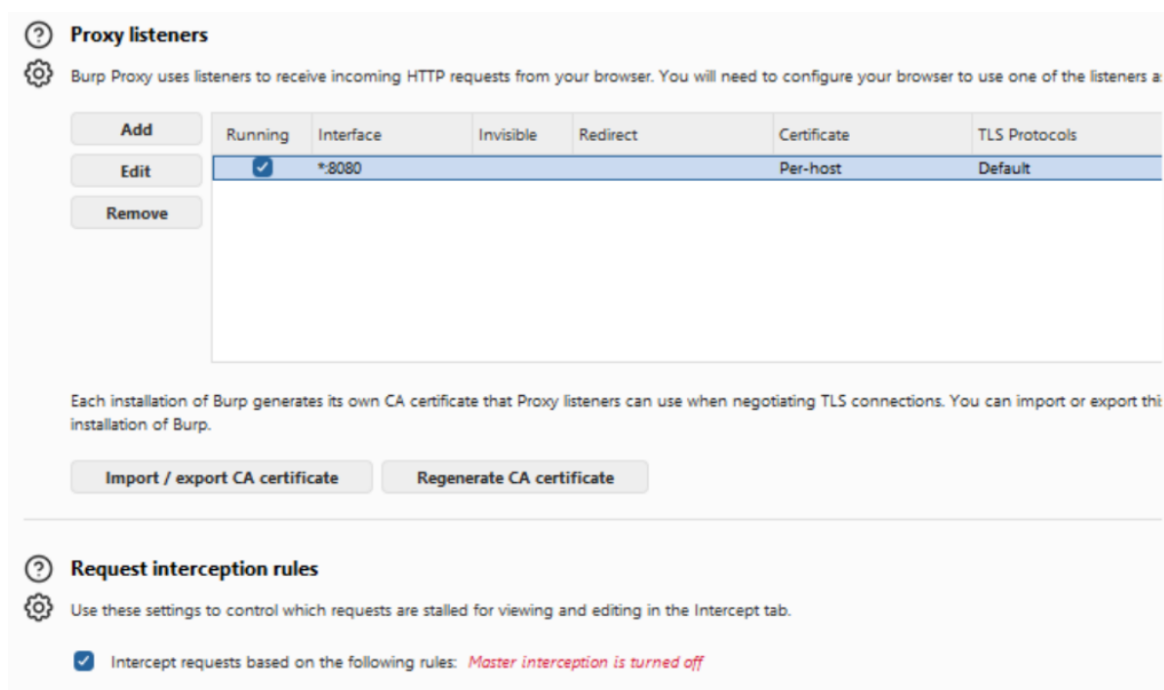


FIGURE 1 – Burp Suite : ecouteur proxy actif sur le port 8080. Cette capture montre que le proxy est pret a intercepter le trafic HTTPS.

```
PS C:\Users\hp> adb shell settings put global http_proxy 10.0.2.2:8080
PS C:\Users\hp> adb shell settings get global http_proxy
10.0.2.2:8080
```

FIGURE 2 – Commande ADB pour configurer un proxy global. La capture montre la mise en place de la redirection vers le proxy local du poste d'analyse.

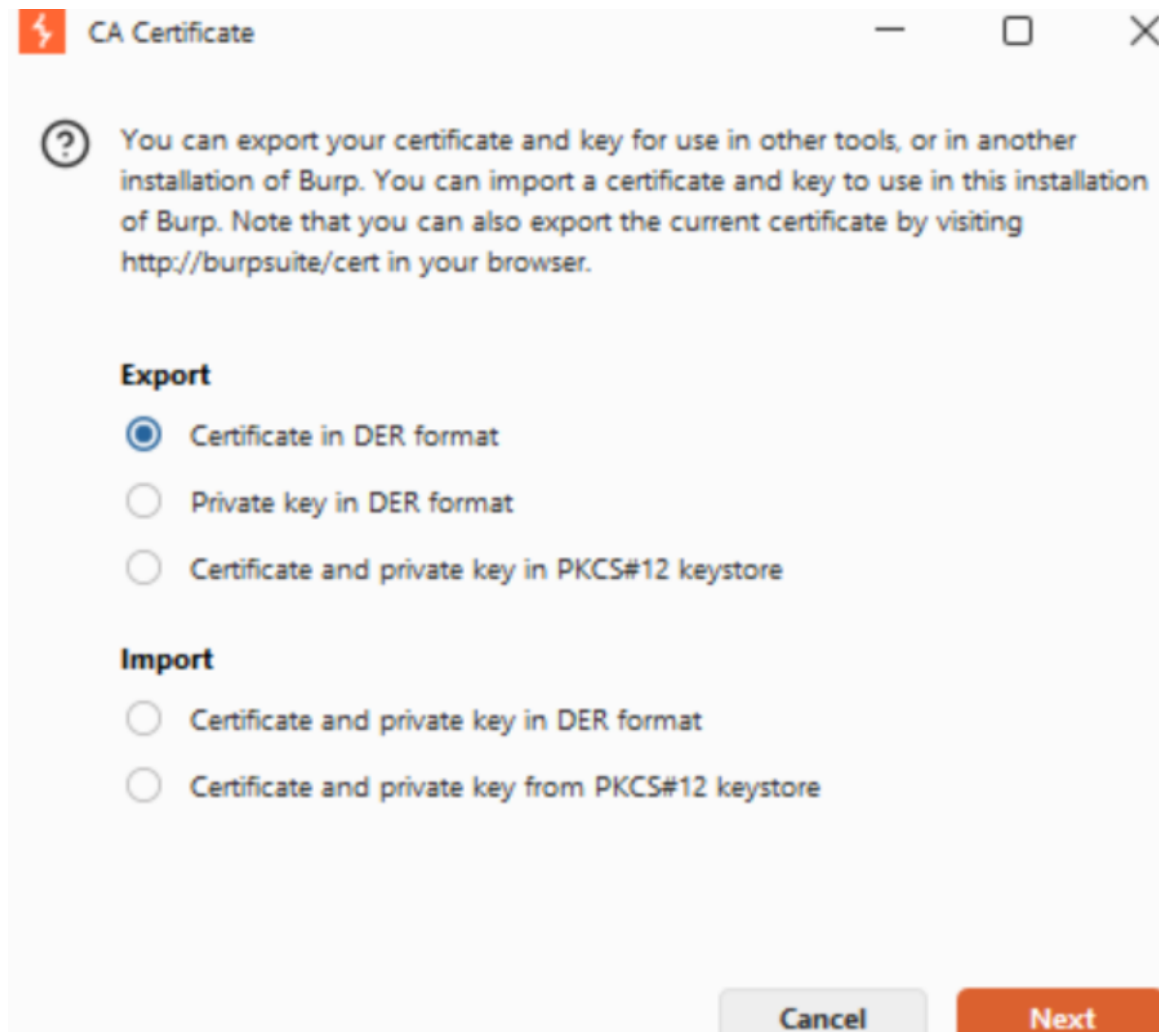


FIGURE 3 – Export ou import du certificat CA du proxy. Cette étape est indispensable pour que l'appareil fasse confiance au proxy TLS.

```
PS C:\WINDOWS\system32> frida-ps -Uai
PID  Name                Identifier
-----
3901  Google                com.google.android.googlequicksearchbox
7880  Phone                 com.google.android.dialer
7842  Photos                com.google.android.apps.photos
1715  SIM Toolkit           com.android.stk
8176  Settings              com.android.settings
-   Calendar             com.google.android.calendar
-   Camera               com.android.camera2
-   Chrome              com.android.chrome
-   Clock               com.google.android.deskclock
-   Contacts            com.google.android.contacts
-   Drive               com.google.android.apps.docs
-   Files               com.google.android.documentsui
-   Glasses             com.google.android.glasses.companion
-   Gmail               com.google.android.gm
-   Maps               com.google.android.apps.maps
-   Messages            com.google.android.apps.messaging
-   Personal Safety     com.google.android.apps.safetyhub
-   YouTube             com.google.android.youtube
-   YouTube Music       com.google.android.apps.youtube.music
PS C:\WINDOWS\system32>
```

FIGURE 4 – Verification avec `frida-ps -Uai`. La liste des applications confirme que Frida voit correctement les processus Android accessibles.

```

PS C:\WINDOWS\System32> frida -U -p 12140 -l "C:\S2\programmation mobile\sslpin_bypass_universal.js"

  /---\
 | C |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
  > _ |
  /_/_|   Commands:
         help      -> Displays the help system
         object?   -> Display information about 'object'
         exit/quit -> Exit

         More info at https://frida.re/docs/home/

         Connected to Android Emulator 5554 (id=emulator-5554)
Attaching...
[+] SSL bypass: SSLContext.init patched
[+] SSL bypass: X509TrustManager patches attempted
[+] SSL bypass: com.android.org.conscrypt.TrustManagerImpl patched
[+] Universal SSL pinning bypass installed
[Android Emulator 5554::PID:12140 ]-> |

```

FIGURE 5 – Console Frida : chargement du script universel et affichage des premiers messages de bypass SSL.

```

PS C:\Users\hp> frida -U -p 11431 -l "C:\S2\programmation mobile\sslpin_bypass_universal.js"

  /---\
 | C |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
  > _ |
  /_/_|   Commands:
         help      -> Displays the help system
         object?   -> Display information about 'object'
         exit/quit -> Exit

         More info at https://frida.re/docs/home/

         Connected to Android Emulator 5554 (id=emulator-5554)
Attaching...
[+] SSL bypass: SSLContext.init patched
[+] SSL bypass: X509TrustManager patches attempted
[+] SSL bypass: com.android.org.conscrypt.TrustManagerImpl patched
[+] Universal SSL pinning bypass installed
[Android Emulator 5554::PID:11431 ]-> |

```

FIGURE 6 – Deuxieme capture Frida montrant la reussite des patchs sur `SSLContext.init` et `TrustManagerImpl`.

Filter settings: Hiding CSS and image content; hiding specific extensions											
Host	Method	Params	Edited	Status code	URL	Length	MIME type	Extension	Title	Notes	TLS
https://accounts.google.com	POST		✓	200	/ListAccounts?gsia=1&source=Ch...	1956	JSON		Example Domain		✓
http://example.com	GET			200	/	801	HTML				✓
https://www.gstatic.com	GET		✓	200	/chrome/intelligence/assist/lania/...	4719	HTML	bin			✓
https://www.google.com	GET		✓	200	/complete/search?client=chrome&...	828	script				✓
https://www.google.com	GET		✓	200	/complete/search?client=chrome&...	2103	script				✓
https://www.google.com	GET		✓	200	/complete/search?client=chrome&...	1872	script				✓
https://www.google.com	GET		✓	200	/complete/search?client=chrome&...	1865	script				✓
https://www.google.com	GET		✓	200	/complete/search?client=chrome&...	1886	script				✓
https://www.google.com	GET		✓	200	/search?q=google&oq=google&a...	92911	HTML		Google Search		✓
https://www.google.com	GET		✓	200	/search?q=google&oq=google&a...	64999	HTML		google - Recherche G...		✓
https://www.google.com	GET		✓	200	/search?q=google&oq=google&a...	828	script				✓

FIGURE 7 – Burp Suite : table de trafic intercepté. Cette vue confirme que les requetes HTTPS de l'application apparaissent dans le proxy apres contournement.

10 Resultats obtenus

A l'issue du TP, la chaine suivante est validee :

1. Frida fonctionne sur le PC et sur l'appareil Android ;
2. le proxy TLS est accessible depuis le telephone ou l'emulateur ;
3. le certificat CA du proxy est installe ;

4. les hooks Frida neutralisent les controles de certificat ;
5. le trafic HTTPS de l'application apparait dans le proxy en clair.

La combinaison de ces elements permet de diagnostiquer efficacement les protections reseau d'une application mobile dans un cadre de test autorise.

11 Difficultes et depannage

11.1 Erreur de connexion a frida-server

Causes frequentes :

- appareil non visible dans `adb devices` ;
- version PC et serveur Frida differentes ;
- `frida-server` n'est pas lance ou n'a pas les bons droits ;
- besoin eventuel de redirection de ports ADB.

11.2 Aucun trafic dans le proxy

Verifier d'abord :

- la presence et la confiance du certificat CA ;
- le bon port du proxy ;
- la connectivite reseau entre l'appareil et le PC ;
- le mode de lancement `-f` ou `-n` ;
- un eventuel pinning natif ou une pile reseau differente.

11.3 Crash au demarrage

Dans ce cas, il est conseille de commencer par un script minimal, puis d'ajouter les hooks un par un. Cela permet d'isoler le point de rupture.

12 Conclusion

Ce TP montre comment assembler un environnement complet d'analyse du trafic HTTPS sur Android. Frida permet d'agir tres tot dans le cycle de vie de l'application, tandis que le proxy TLS fournit la visualisation du trafic dechiffre. L'approche reste tres efficace pour l'audit et la formation, a condition de respecter strictement le cadre legal et de retirer ensuite les composants de test.

Livrables

- ce rapport PDF ;
- le fichier source $\text{\LaTeX}$;
- un README de synthese pour le depot du TP ;
- les captures d’ecran organisees dans le document.